Team Caffeinated Nerds · Challenge: **Frontier · PS-04** · Fast and Secure Online Transaction Authentication

Bhavyam Misra
Roll No: 1024030535

Gunagye Jain
Roll No: 1024030019

Abhijay Nagal
Roll No: 1024170013

Shefali Sharma
Roll No: 1024030284

Problem, Stakeholder & SDGs

> Fraud has moved past OTPs: victims now approve the payment themselves

PROBLEM

Asha, 72, gets a call from a fake "CBI officer", opens UPI on her own phone and types her own PIN: **approved**, and ₹85,000 goes to a scammer. A static PIN/OTP proves **who you are**; nobody checks **what's happening** (a call in progress, a pasted new payee, a SIM swapped yesterday).

TARGET STAKEHOLDER

Banks, UPI apps & payment gateways that must allow / challenge / block within UPI's 15-second window, on behalf of everyday users, especially **seniors and first-time digital payers**.

WHY IT IS WORTH SOLVING

Losses tripled from 2023 to 2024. RBI's proposed fix is a **blanket 1-hour delay on every ₹10k+ transfer**, adding friction for all honest users. A precise, explainable risk check stops the scam and keeps honest payments instant. RBI's 2025 rules already allow risk-based extra checks.

EVIDENCE

₹22,495 cr
lost to cyber fraud in 2025: 28 lakh complaints, +24% year on year (MHA / NCRP)

~85%
of 2025 losses came from investment & "digital arrest" scams, where the victim pays (MHA)

98.5%
of fraud value is in payments above ₹10,000. RBI: account takeover is "now negligible", most fraud is authorised push payment (RBI, Apr 2026)

PRIMARY · SDG 16
16.4: cut illicit financial flows & organised crime

SUPPORTING · SDG 8
8.10: access to financial services for all

SUPPORTING · SDG 9
9.1: reliable, resilient (digital) infrastructure

Sources: MHA/NCRP data via Parliament replies (2024, 2025); RBI Discussion Paper on safeguards in digital payments, 9 Apr 2026; RBI Authentication Directions, 25 Sep 2025. Links: repo › docs/02-research/problem-evidence.md

Existing Approaches & Gap

> Today's defences check the credential or the receiver, never the moment

1 · Static two-factor auth

UPI PIN · SMS OTP · 3-D Secure

What it does

Device binding + PIN/OTP on every payment. RBI keeps 2FA as the minimum from April 2026.

What's still missing

Checks the credential, not the context. Coached victims type it in; SIM-swap steals it. Same friction for a ₹50 tea and a ₹2 lakh transfer.

2 · Commercial risk engines

Stripe Radar · Sift · BioCatch · 3DS-2 issuer engines

What it does

ML score over hundreds of signals → block / review / ask for 3DS. BioCatch adds behavioural biometrics.

What's still missing

Proprietary, priced for large players, sold as separate products. Gives analysts a score, not the customer a reason. The challenge is a generic OTP whatever the risk.

3 · India's ecosystem tools

NPCI FRM · DoT FRI · RBI MuleHunter.AI · DPIP (pilot)

What it does

Shared intelligence on risky numbers and mule accounts; alerts to banks. RBI also proposes blanket delays & trusted-person approval.

What's still missing

Reputation after the fact: a number must be reported first, and scam numbers live only days. Scores the receiver, not this session. Blanket rules add friction for everyone.

The gap we are addressing is: no lightweight, real-time service fuses behaviour + device + transaction context into an explained allow / challenge / block decision that also picks the **right kind** of challenge. Coached victims get stopped; honest payments stay instant.

Sources: RBI press release 25 Sep 2025 & Discussion Paper 9 Apr 2026; Stripe Radar docs (risk evaluation); Sift; BioCatch (remote-access scams; India 2024 report); NPCI FRM; DoT FRI (May 2025); IBTimes on IDPIC/MuleHunter (Sep 2026). Links: repo › docs/02-research/prior-art.md

Proposed Solution

> Pramaan: a PIN checks who you are. We check what's happening, before every payment.

WHAT WE BUILD

A cloud risk API that banks and UPI apps call **before** PIN/OTP. It returns **allow / challenge / block** in milliseconds, with plain-language reasons. It adds to mandated 2FA; it never replaces it.

CORE FUNCTIONALITY

- **20+ signals** (behaviour, device, transaction, receiver) scored against each user's own history
- **Hybrid engine:** policy rules + gradient-boosted model, with each signal's contribution explained
- **Amount-aware:** a ₹40 tea is never stopped; an ₹85k first-time transfer is checked closely
- **4 levels of response:** allow · fingerprint for a likely impostor · 30-min hold, scam warning + trusted contact for a likely scam victim · block

WHY THIS CLOSES THE GAP

An OTP can't stop someone who is being coached. A pause and a family member who can cancel can. We use them **only** when the context is risky, unlike RBI's proposed blanket 1-hour delay: honest payments stay instant, risky ones get stopped. Free, open tools: **₹0 running cost**.

USER INTERACTION: 4 levels · the same ₹85,000 payment, four situations

Usual payee, own phone, normal typing
Risk 0.04 · pays instantly, no extra step
① ALLOW

New phone, SIM swapped 20 h ago, new city
Risk 0.58 · impostor: owner's fingerprint
② BIOMETRIC

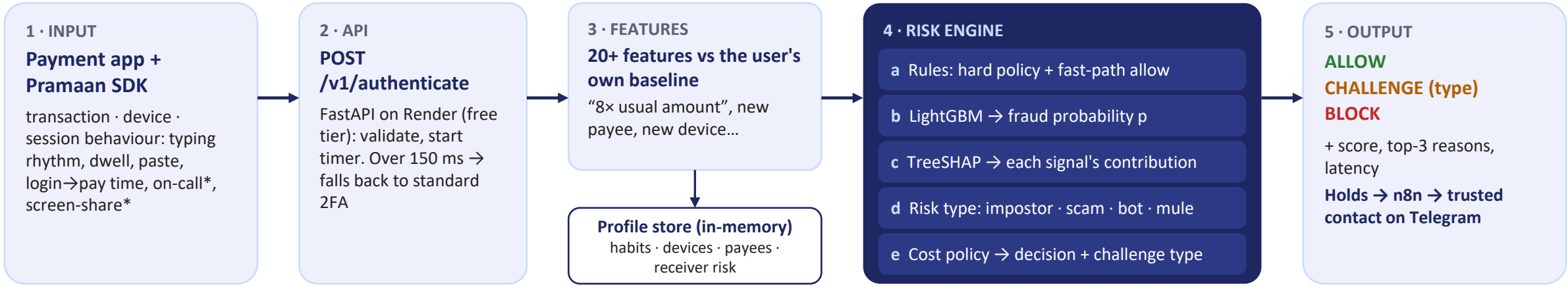
On a call, new UPI ID pasted, own phone
Risk 0.71 · scam: 30-min hold, son cancels
③ HOLD + CONTACT

Emulator + VPN, 15 attempts in 10 minutes
Risk 0.97 · bot: blocked, analyst alerted
④ BLOCK

Analyst console: every decision live with its "why" (on a call +0.31, pasted new UPI ID +0.24, 6× usual amount +0.13); feedback retrains the model.

Technical Approach

> One API call: context in, an explained decision out, in milliseconds



Built during the hack: SDK + demo app, API, risk engine, passkey fingerprint, n8n + Telegram family loop, replay simulator, live dashboard, deploy. **Mocked:** bank/NPCI rails, FRI & mule feeds, *phone call-state.

STACK (all free, ₹0 running cost)

- Python · FastAPI · LightGBM · SHAP on Render (no card) · React on Vercel · Supabase free tier
- n8n (self-hosted) + Telegram Bot API: hold → family Approve/Cancel → timeout → label
- WebAuthn passkeys for fingerprint · replay simulator: our policy vs RBI's blanket delay

DATA

- No public dataset has all three signal families → synthetic generator: 5k users, 30 days, 4 labelled attack types + hard negatives (travel, new phone, rent)
- Sanity-checked on IEEE-CIS (590k txns) & PaySim · *call state: mobile SDK, toggles in demo

DECISION RULE

- Block if $p \geq 0.90$ or a hard rule fires
- Challenge if $p \geq \text{clip}(₹500 \div \text{amount}, 0.05, 0.60)$: stricter as the amount grows
- Challenge type = lowest friction + p × amount × (1 − effectiveness vs this risk type)

Build Plan, Risks & Impact

> A deployed, working prototype in the hack, honest about its limits

1 · WHAT WE WOULD BUILD

A working prototype by the end of the hack:

- Live /v1/authenticate (Render, free) with fail-safe
- Risk engine: rules + LightGBM + TreeSHAP + cost policy
- 4 levels live: passkey fingerprint, n8n + Telegram family loop
- Demo UPI app + SDK; dashboard with "why" panel
- Replay simulator vs RBI's blanket delay; synthetic data

Plan (hack hours)

H0–6 data + scaffolding · H6–12 engine + API · H8–16 app, passkeys, n8n loop · H12–18 dashboard, simulator, tests · H18+ deploy + rehearse

Cost: ₹0, free tiers + open source, no paid APIs.

2 · RISKS & LIMITATIONS

Data realism. Synthetic ≠ real fraud. → *hard negatives, per-type metrics, IEEE-CIS/PaySim check; retrain on bank history in a pilot.*

Signal access. Call/screen-share state needs a mobile SDK + app adoption. → *missing = "unknown", never "safe"; Google is already piloting screen-share alerts in GPay/Paytm.*

False positives. Delaying a genuine urgent payment hurts. → *block only at p ≥ 0.9, ≤ 5% challenge budget, cancel/whitelist, feedback loop.*

Privacy & adaptation. DPDP consent rules (from 13 Nov 2026); scammers adapt. → *derived features only, hashed IDs; no single signal decides; retraining.*

3 · EXPECTED IMPACT

Honest payments stay instant. Only risky ones are stopped: the scams OTP can't catch.

≥ 80%	of scam-type fraud caught while ≤ 5% of legit payments are challenged (OTP-only: ~0%)
≥ 90%	of legit ₹10k+ transfers pass with no delay (a blanket 1-hour rule delays 100%)
< 50 ms	p95 decision latency, well inside UPI's 15-second window

Fast. Secure. Explained. Targets measured live on held-out synthetic data.